Securing Claude Cowork: Controls, Gaps and Safer Defaults

What the admin console, device policy and third-party deployments actually control, and where they fall short.

M. Walker · Practitioner reference

EVIDENCE CUT 23 Sep 2026 | FRESHNESS SCAN 40 days | REFERENCES 65 | VERSION 1.4

1 Claude Cowork Overview

Thick Client

Cowork runs inside the Claude Desktop thick client (Mac, Windows 10/11, and Linux since 30 June 2026, in beta for Debian and Ubuntu with updates through the system package manager) alongside two other apps, Chat and Claude Code [4, 38]. The three are tightly linked. In 3P, one managed configuration and one engine govern all three, and Chat file analysis uses Cowork's shell tool [30, 36]. In 1P, a single network access setting governs cloud Cowork, local Cowork and chat [3]. Cowork sessions now run in Anthropic's cloud by default rather than in the local VM, and local execution remains available for existing desktop deployments [3]. Team tenants start with cloud execution on. Enterprise tenants start with it off, under a separate Run Cowork in the cloud setting, and the owner must also grant the Cowork in the cloud capability to a group through custom roles [2]. See 2.7.

Naming note, 23 September 2026. Anthropic began rolling out one Claude, merging Cowork and chat, to Pro and Max on 16 September 2026 [1, 27]. Team and Enterprise organisations keep chat and Cowork as they are today, and Anthropic has promised Enterprise admins at least 30 days' notice before anything changes [1, 2]. The admin settings (Organization settings, Cowork, and Run Cowork in the cloud) and the 3P keys (coworkTabEnabled, coworkEgressAllowedHosts) still say Cowork, so this sheet does too. The 3P product is now documented as Claude Desktop on 3P [28].

Third-Party Inference Configuration (Claude Desktop on 3P)

"Claude Desktop on 3P" is a Claude Desktop configuration for third-party inference (Google Cloud's Agent Platform, formerly Vertex AI, AWS Bedrock, Microsoft Foundry, a gateway implementing the Anthropic Messages API, or the Anthropic API directly). It runs on a different control plane, MDM policy, while offering increased confidentiality together with Australian data residency for inference where the chosen model is offered in an Australian

Bedrock or Vertex region. Anthropic names Asia/Pacific regions only, so check the provider's model availability for Australia [28]. Anthropic-operated download and telemetry hosts remain (see 2.4.2). Foundry does not currently support this. On Microsoft Foundry, Anthropic operates the Claude models, and Azure hosted Foundry offers Global Standard or US Data Zone Standard residency only [28]. Microsoft's own page still says equivalent guarantees are coming for Foundry [42]. The Chat tab is available in this mode, generally available since 14 July 2026 and hidden until an administrator sets chatTabEnabled.

An organisation that manages 3P from the claude.ai Enterprise Admin Console (beta) signs users in with a Claude account. The app then contacts api.anthropic.com at every launch and every configuration re-check, and Anthropic holds the user list and the saved configuration [33, 28]. That gives up the "no Anthropic account" premise the 3P confidentiality argument rests on. Gateway deployments, and since 22 September 2026 Bedrock deployments too (inferenceCredentialKind: "external-idp"), can authenticate inference through the organisation's own OIDC identity provider, which keeps identity with the customer [38].

Component	Standard Cowork	Claude Desktop on 3P
Model inference	Anthropic API	Your Agent Platform (Vertex AI) / Bedrock / Foundry / gateway endpoint, or the Anthropic API directly
Web application	Loaded from claude.ai	Bundled inside the desktop app
User identity	Anthropic account	Local device identity only, the organisation's own OIDC identity provider (gateway, and Bedrock since 22 September 2026), or an Anthropic account when managed from the claude.ai admin console
Conversation storage	Anthropic backend	Local disk on the user's machine
Code execution sandbox	Anthropic cloud (on by default for Team, off by default for Enterprise) or local VM for existing desktop deployments	Local VM only. No cloud execution in 3P
Chat tab	Present	Present since 16 June 2026, generally available 14 July 2026, off unless chatTabEnabled is set. Shown with Cowork as Home since 6 August 2026
Chat file analysis sandbox	Governed by the claude.ai code execution setting	chatAdvancedFileAnalysisEnabled. Reads attached files, and project memory read only inside a project. No network access

Component	Standard Cowork	Claude Desktop on 3P
Session content for eDiscovery	Compliance API, generally available for Enterprise since 26 August 2026 (beta from 3 August for web and mobile, 11 August for desktop), retrieval only	Not captured by Anthropic. Transcripts sit on local disk. Device retention and legal hold keys (coworkSessionRetentionDays, sessionRetentionHold) since 10 September 2026
Configuration	Admin console at claude.ai, plus device policy (MDM) for Desktop	One of the claude.ai Enterprise Admin Console (beta), OS-native configuration (MDM-managed or per-user), or a bootstrap server

Missing 3P Features

Still absent or withheld in 3P:

- Computer use. Anthropic's feature matrix shows it absent from 3P, and absent for Claude Enterprise too [29].
- The default Anthropic plugin marketplace, removed from 3P deployments on 2 July 2026. Provision your own through allowedPluginMarketplaces, out of beta since 27 August 2026. Since that same date the setup window pre-fills Anthropic's Cowork and Claude Code marketplaces, so the default sits one click away from being restored [38, 31].
  - Hosted (url) marketplaces can be pinned by SHA-256 (manifestSha256, beta, since 17 August 2026), and pinning is required for automatically installed plugins [38].
  - userPluginMarketplacesEnabled and userPluginUploadsEnabled (25 August 2026) block member-added marketplaces and uploads. allowedPluginMcpServers (17 September 2026) limits which plugin MCP servers can connect [38].

Features that 3P previously lacked and now has:

- The Chat tab, generally available 14 July 2026.
- Projects, added 4 August 2026 and available even where the Cowork tab is turned off.
- Claude in Chrome, since September 2026, and only in organisations managed from the Enterprise Admin Console [29, 35].
- A built-in browser, since 17 September 2026 (v2.2553.0), through builtinBrowserEnabled (default false) with domain policy keys [35, 38].

The Chat file analysis sandbox reads only the files attached to the conversation (plus, for a chat inside a project, that project's memory, read only), writes only inside the session directory, and has no network access, unconditionally and independent of coworkEgressAllowedHosts. That makes it a tighter boundary than Cowork's VM [36]. It runs in the same local VM and shell tool as Cowork. Adding Bash to disabledBuiltinTools

disables it. Since 15 September 2026 neither Chat nor Cowork asks for approval at each analysis step, though connector actions still ask, unless "Bash": "ask" is set in builtinToolPolicy [38]. My assessment: in 3P, do file analysis in Chat rather than Cowork wherever the task allows.

Cowork Control Planes & Hierarchy

Priority	1P Cowork	Claude Desktop on 3P
1	Claude.ai Organisation Settings	3rd Party Inference Provider
2	Device policy (MDM), Team and Enterprise	One delivery model: Enterprise Admin Console (beta), MDM policy, or bootstrap server
3	Local User In-App Preferences	Local Config (%LOCALAPPDATA%\Claude-3p/configLibrary)
4		Local User In-App Preferences

* 3P Local Config should be used only for temporary testing.

1P device policy overrides the in-app extension allowlist, and machine policy beats user policy [5]. The local config path is unchanged. The 3P hierarchy now starts with a choice of delivery model. Five refinements matter:

- The three 3P delivery models do not combine [32]. A device carrying any MDM key outside the app-behaviour group ignores the admin console, and a bootstrap response replaces MDM values wholesale.
- Windows does not merge the policy hives. If HKLM carries a managed configuration, HKCU is ignored entirely.
- A managed source overrides local values, with one exception: the app-behaviour group, which is enforced as a unit. That group covers the update keys (including updateViaUpdatesHost), relaunchEnforcementHours, configRecheckIntervalMinutes and the proxy keys [30]. Only disableAutoUpdates pins the client version. autoUpdaterEnforcementHours is a force-install window.
- Linux reads machine policy from /etc/claude-desktop/managed-settings.json, root owned.
- A bootstrap server can now push remote configuration. The consent prompt under trustBootstrapDelivery covers sensitive values only (credential helpers, endpoints, local commands, connectors), and by default there is no prompt at all when the bootstrap URL comes from machine-scoped MDM [34]. The configuration reference describes the prompt as the default in all cases, so Anthropic's two pages differ [30]. The old key name trustBootstrapLocalExec is rejected after 7 October 2026 and then reads as false [30, 31]. Treat it as a control plane, not a convenience.

2 Key Controls Challenges

2.1 Critically Dangerous Defaults

Both the 1P and the 3P configuration ship defaults that will hurt you, and some of them look harmless until you read what they actually do:

- The monthly spend limit defaults to unlimited. In 3P, inferenceMaxTokensPerWindow does nothing unless the cap and the window are both set, and once they are it is still a per-user soft cap counted on the client, not a quota the server enforces [30].
- 'Rate Chats' defaults to enabled. That is my inference, because Anthropic does not state the default. One click stores the entire conversation, including content, custom styles, preferences and model settings, for five years, and Anthropic may use it to train models. Despite the Enterprise headline of no training on your data by default, the click counts as an opt in. Feedback excludes raw connector content unless it was copied into the conversation, and Anthropic de-links feedback from user and customer IDs. Disable at Organization settings, Data and Privacy [14].
- Plugins and connectors are open by default. A Knowledge Work marketplace is added to every organisation [8]. Plugins set to Installed by default or Required also install into Claude Code, where their hooks, sub-agents and MCP servers run on the user's computer, and turning off Cowork does not stop that sync [8]. Enterprise custom roles have carried per connector and per tool permissions (Always allow, Needs approval or Blocked) since 28 May 2026, enforced on Anthropic's servers, but only for members on a Custom role, not for locally run connectors and not in 3P [6, 7, 13]. Outside those roles, enabling a connector makes it available to everyone, and each member still signs in [11]. Default counts move with each release, so check the tenant rather than a published figure.
- Anthropic describes new custom roles as permissive by default: chat on, every organisation-enabled model available, and connectors at Needs approval. Check each tab before saving. Roles set to All capabilities also pick up new capabilities as they launch [6, 7]. When Anthropic enables connector permissions for an organisation, its existing roles are seeded with Always allow [6].
- Organisation provisioned skills are on for every user across web chat, the Chat tab and Cowork. A user can switch one off but cannot delete it. Provisioned skills also load in Claude Code for users who sign in with their Claude account. The admin fix is syncClaudeAiSkills: false in Claude Code managed settings [9].
- Allow Automatically approve mode is on by default for Team and Enterprise [2, 15]. Anthropic's 3P feature matrix (17 September 2026) says the mode is not available for Claude Enterprise [29]. That conflict is unresolved, so check the tenant.
- The built-in browser and Claude in Chrome both default on for Enterprise from 10 September 2026 unless an owner had turned them off. See 2.2.

- Owners cannot restrict project creation [2]. Share projects and Public projects are both on by default, and turning sharing off does not revoke existing user and group shares, though existing public projects become private. On Enterprise, sharing can be set per custom role [17].
- Artifacts can be shared by email with people outside the organisation (beta), on by default for Team and off for Enterprise, at Organization settings, Artifacts. Any member of the organisation who can edit an artifact can invite outsiders (up to 50 per artifact) once the owner sets a Shared version, and accepted invitations never expire. Cowork produces artifacts, so this is an output path outside every egress control. Admins can see and revoke outside access under Published artifacts [16].

Where 3P is in use there are levers [30]:

- skillCreationEnabled hides skill creation and disables the agent's own skill creation tools. One user report on GitHub says it is not enforced when delivered through the Claude apps gateway [64]. That is unverified, so test it on your build.
- mcpPersistentAlwaysAllowEnabled removes the persistent Always allow choice. Since 22 September 2026 mcpScheduledTaskApprovalLifetimeDays offers a lasting approval for scheduled tasks even while persistent approvals are off, so set that to 0 as well [30, 38].
- disableBypassPermissionsMode (4 September 2026, off by default) removes the bypass permissions mode from Code and Cowork. Until it is set, the mode is available in 3P [30, 38].
- managedMcpServers toolPolicy supports blocked, ask and allow with wildcards, which is what a deny by default posture needs. Unrecognised values fail to the most restrictive setting. ask-session is deprecated: it behaves exactly as ask and is accepted until 7 October 2026, after which the app rejects the entry and that connector becomes unavailable [30, 31].
- Before 7 October 2026, search existing profiles for every spelling caught by that cut-off, about 20 in all. They include ask-session in builtinToolPolicy and orgPluginSettings, inferenceGatewayAuthScheme values sso and auto, the string or list forms of otlpHeaders, bootstrapHeaders and inferenceCustomHeaders, enduserAttribution, trustBootstrapLocalExec, isDxtEnabled, isDxtSignatureRequired and the orgPluginSettings record form. An undocumented client certificate fallback setting stops being accepted on 17 November 2026 [30, 31, 38].

Several defaults are tighter than v1.2 of this sheet said, and some of them were missed at its cut: new custom roles default to Needs approval on every connector [6], Always allow for connector tools is off by default [2], network egress is off on new Enterprise organisations [23], memory is off by default for Team and Enterprise since 25 August 2026 [13], and from 2 October 2026 security scanning is on by default for Enterprise organisations that have not set it [9]. The same date moves skill publishing to Requires review for organisations that have not chosen, which is tighter for Team (from Open) but looser for Enterprise (from Off) [9]. New permissive defaults keep arriving. Check each release against the tenant, not against this sheet.

2.2 Unrestricted Computer Use

Computer use is off by default, remains Pro and Max only, and has no administrative control on any plan. Anthropic states that Team and Enterprise do not have access, and there is no published date for Enterprise availability [18]. There is still no sandbox: in Anthropic's own wording it has "no sandbox between Claude and your applications". Once enabled it runs with the user's privileges. It asks permission before accessing each application and some apps are off limits by default, but it can still reach applications it was never granted (a link in a mail client opening in Chrome), and it takes screenshots of whatever is visible, including material unrelated to the task [18, 50].

Claude in Chrome is now administered separately: enabled by default on Team. On Enterprise it was disabled by default, and from 10 September 2026 it turns on by default unless an owner had already disabled it. Site allowlist and blocklist controls sit at Organization settings [19]. On Enterprise, once cloud Cowork is enabled the side panel becomes a Cowork session and existing Chrome users switch over automatically, so the cloud Cowork toggle and the Chrome toggle are one decision. Zero data retention is not supported for Claude in Chrome [19]. Three independent research reports (LayerX's ClaudeBleed in April, Manifold Security in July, Forever Security's BragJack in September 2026) show that another installed extension can drive Claude in Chrome [51, 52, 53]. Manifold reported its two flaws unpatched in v1.0.80. Anthropic rated BragJack medium and paid a bounty with no fix date. None of the three is marked fixed, so keep Chrome off, or allowlist extensions, until Anthropic says otherwise.

Claude Desktop also has a built-in browser for Cowork, controlled at Organization settings, Cowork, separately from Claude in Chrome. It is on by default for Team. On Enterprise it was off at launch and is on by default from 10 September 2026 [20, 21]. Anything a user signs in to inside the built-in browser is available to Claude in future Cowork sessions on that computer. An Import cookies step brings saved logins across from Chrome, Edge and Firefox (Chrome and Edge on macOS only), with banking, email and SSO sites unchecked by default, and no admin control over the import is documented [20]. Browser traffic leaves from the user's machine even when the session runs in the cloud [2]. Anthropic does not say whether network egress settings apply to the built-in browser. They do not apply to web fetch, web search or Claude in Chrome [2].

Computer use cannot be governed inside Anthropic's controls, so govern it at identity and endpoint. Two controls bind: Tenant restrictions at the proxy [22], and forceLoginOrgUUID in 1P Desktop device policy, which makes sign-in fail for any account outside the listed organisations [5]. Both keep personal Pro and Max accounts off managed devices. That this also keeps computer use off is my inference from two documented facts, not an Anthropic statement.

2.3 Missing Controls in First-Party Configuration

Model choice is the one area where 1P has caught up. Enterprise administrators can set an organisation default model and restrict which models each custom role may use, with a per model effort cap, at Organization settings, Models and under each role. Haiku cannot be disabled, so a fallback always exists [12]. Claude Code honours availableModels in the CLI

and IDE only, not in Claude Code on web or desktop [12]. The related enforceAvailableModels key is not documented in the sources cited here.

The remaining 1P controls sit in one of three places, and most of them are not in the admin console.

Admin console (Organization settings)

- Model access, as above.
- Inference hooks (beta, Enterprise, since 5 August 2026, missed at the v1.2 cut). Each governed prompt across claude.ai, Cowork and Claude Code is held for the organisation's AI security server to allow or deny before inference. It is the first inline, deny capable control over 1P Cowork content [39].

Device policy (MDM), Team and Enterprise

These are Desktop policy keys rather than admin console settings, so they bind only on managed endpoints [5].

- Cowork and the Code tab on or off: secureVmFeaturesEnabled and isClaudeCodeForDesktopEnabled.
- Auto updates: disableAutoUpdates and autoUpdaterEnforcementHours.
- File system access: allowedWorkspaceFolders, "Filepath or filepaths the user can mount to Cowork". In 3P the same key adds per entry read only mode and pre-selected folders, but in Code sessions read only binds the file tools only, not Bash or SSH [30].
- Sign-in: forceLoginOrgUUID (see 2.2).

Nowhere in 1P

- The code interpreter and bash for Cowork cannot be disabled in favour of simple file read and write. The claude.ai code interpreter toggle governs the Chat app only. The 3P lever is disabledBuiltinTools with Bash. disableBundledSkills governs Claude Code's bundled skills and is not a code interpreter control [30].
- Telemetry egress cannot be blocked. Claude Enterprise does not offer telemetry toggles [29]. 3P uses disableEssentialTelemetry, disableNonessentialTelemetry and disableNonessentialServices.
- Computer use cannot be restricted from either control plane, and it is absent from 3P too, so it is not a 3P over 1P gap. See 2.2.

With cost control settled, every gap that remains governs what Cowork can execute, reach or read.

2.4 Confusing Egress Controls

2.4.1 "1P"

Four points decide what a first-party session can reach, and none of them is quite what the setting name promises.

- Turning off web_search does not take Cowork offline. web_fetch and bash both remain. Web fetch runs server side and is limited to search results and URLs the user shared, and bash follows the egress setting [2].
- Egress has four options under Organization settings, Capabilities: off, package managers only, package managers plus specific domains, or all domains. New Enterprise organisations start with egress off, and cloud sessions use the same setting [23, 3]. For Team, Anthropic's own article gives both package managers only and off, so check the tenant [23]. Network settings apply only when a new session is created [2].
- Web fetch, web search and MCP connections, including Claude in Chrome, reach the network regardless of the egress settings [2].
- web_search runs server side at Anthropic and returns page content along with results, not only links [41, 24].

2.4.2 "3P"

Third-party egress rests on one key, and most of what matters is the traffic that key never sees.

- coworkEgressAllowedHosts accepts exact hosts, wildcards such as *.corp.com that match subdomains at any depth but not the apex, a bare wildcard, and a port suffix, across both the Cowork and Code tabs. Ports are enforced in Cowork, but the Code translation treats them as the bare host. The key does not cover Web Search (which runs at the inference provider), inference or MCP traffic [30].
- Shell commands and package installs run in a network sandbox that reaches only the listed hosts plus the inference provider. IP addresses match only when listed exactly, and localhost and private-network addresses are always blocked for web fetch. Setting * switches the shell network sandbox off [30]. AWS's ccwb tooling sets coworkEgressAllowedHosts to ["*"] automatically when web search is enabled, which is a trap for Bedrock deployments [43].
- Left unset, the sandbox can reach only the inference endpoint. The app itself still reaches downloads.claude.ai for the VM bundle and CLI unless the offline installer is used. The model catalogue fetch has its own switch, modelCatalogEnabled [30, 28].
- Update and telemetry hosts still egress unless the telemetry and update keys are set. updateViaUpdatesHost allows updates without unblocking api.anthropic.com. Since 22 September 2026 essential telemetry also needs claude.ai, so claude.ai stays reachable unless disableEssentialTelemetry is set [30, 38].

- The documented "Locked down" profile is an illustrative example, not a built-in preset. It leaves the inference endpoint and your OTLP collector as the main paths out, but still reaches downloads.claude.ai unless the offline installer is deployed, needs modelCatalogEnabled: false, and still needs claude.ai for essential telemetry unless that is off. On Foundry, conversation content still reaches Anthropic-operated infrastructure under this profile. Console-managed apps also contact api.anthropic.com and claude.ai [30, 28, 38].
- TLS inspecting corporate proxies with a custom root CA now work.

2.4.3 Enforcement

Whether either allowlist holds is a separate question from how it is written, and the record below is made up of user reports rather than Anthropic statements.

- 1P allowlist entries have been reported ignored, subdomains blocked, and the all domains setting not reaching the session proxy token (user reports on GitHub) [54, 55, 56, 57]. None is marked fixed. 30112 and 34690 remain open, and 19087 and 33386 were closed as duplicates, not fixed.
- Four more user reports followed on 11 September 2026: sessions ignoring All domains (93512, cloud and local, a regression, and 93656, cloud), Specific allowed domains ignored (93520), and local egress blocked after a VM update (93589, closed by its author on 14 September with no Anthropic fix note) [58, 59, 60, 61].
- 3P is not exempt: with a custom gateway the sandbox has been reported pinned to the gateway plus api.anthropic.com, with three independent reproductions (user report, open) [62]. The earlier 3P citation, 56959 (managed allowedDomains ignored on Claude-3p with Bedrock), was closed as a duplicate of 37970 on 11 May 2026, not fixed [63].
- The cloud sandbox reports fail closed. They are not escapes, but they show that the policy feeding an enforced boundary has been reported wrong.
- Put the enforcing control at the network. Treat the in-app allowlist as best effort.

2.5 Unclear Administrative vs Personal Settings Boundaries

For administrators, the boundary between a personal settings change and an organisation wide one is confusing.

- Custom connectors on Team and Enterprise can be added only by Owners, and a connector added that way is organisation level by design, even though each member still signs in individually [10, 11]. A plugin that a member uploads through their own Customize menu installs for that member alone [8].
- Sessions run by an Owner or a Primary Owner do not experience the administrative limits on connectors and plugins set in the organisation admin panel. The exception is organisation wide model disables and effort caps, which do apply to them [6, 12]. Always create a separate unprivileged account to test whether controls are working.

2.6 Session Visibility and the Compliance API

The Compliance API reaches Cowork in the desktop app, on web and on mobile, and Claude Code in the CLI and the desktop app. Web and mobile Cowork transcripts went into beta on 3 August 2026, desktop sessions on 11 August. The session endpoints have been generally available for Enterprise since 26 August 2026, and beta coverage has since extended to Claude Science, Claude for Microsoft 365 (26 August) and Claude in Chrome (18 September) [39]. Only the Primary Owner can enable the API [25]. A transcript carries prompts and responses, web and MCP tool call content, and skills and artifacts content as text, with verified user, organisation, session and per message identifiers. Tool inputs and each tool result text entry are truncated to 10,000 bytes by default, thinking is never included, and images, PDFs and other non-text content appear only as placeholders [40]. Before 3 August 2026 Cowork session content sat outside the Compliance API altogether, so this is a material improvement. Four limits set what it is worth:

- Retrieval only. There are no deletion endpoints for local sessions, so Cowork local sessions do not satisfy a deletion or access request.
- Transcript only. It shows what Claude was asked and what it returned, not what happened on the device. File and network activity surfaces only through tool calls and results, so anything that never reaches the API is not captured. Inference hooks (2.3) and OpenTelemetry (below) partly fill this gap.
- Coverage excludes Claude Code cloud sessions, sessions through a Console API key or a third party cloud, all local session data where HIPAA readiness is enabled, and zero data retention sessions [40, 25]. A Claude Desktop on 3P deployment therefore gets no coverage of session content at all.
- Retention differs by session type. Local transcripts are kept six years by default, or your organisation's finite custom retention period where one is set, and the shortest applies where several are set. Remote transcripts are kept six years unless a user deletes the session sooner, after which the endpoints no longer return it and the transcript is not recoverable [40]. A cloud Cowork transcript is not a legal hold record unless it is exported promptly.

OpenTelemetry is the second visibility source, and it was missed at the v1.2 cut. Team and Enterprise owners can stream Cowork events for cloud and local sessions to their own OTLP collector from Organization settings, Cowork. The events include full prompt text, every tool and MCP call with parameters, the file paths Claude reads or changes, skills and plugins used, approval decisions and user email. Nothing is exported until an endpoint is set, and once it is, prompt content and tool parameters go to the collector by default [26]. Unlike the Compliance API it is real time, available on Team, and records file paths.

Session material also stays on the endpoint. Independent research reports Cowork session logs written world readable at 644, holding complete tool transcripts, model reasoning and user messages in plain text, with child session audit logs and main.log surviving deletion of the session in the interface [48, 49]. A separate user report on GitHub says Delete in the Desktop sidebar leaves a Code tab session's transcript on disk until a later retention sweep [65]. The 3P documentation says its data directory files are written owner only, which covers the 3P application data folder and not the standard Desktop logs the research

examined [37]. Check both. Anthropic does not document this and I have not tested it on a managed build, but it is specific enough to plan for: cover it with endpoint controls rather than assuming deletion in the interface is deletion on disk.

Statements that Cowork activity is invisible to the Compliance API are now out of date for server held transcripts, and still correct for the device.

2.7 Sandbox Escape and the Local Execution Decision

2.7.1 Evidence

The public record here is one published escape, the flaw underneath it, and what Anthropic has and has not done since.

- A working escape from local Cowork execution was published on 23 July 2026. Researchers at Accomplish AI reached guest root inside the VM, then used the writable host mount that Cowork places there to read and write across the whole Mac as the logged in user, outside the connected folder and with no further permission prompt [44].
- What the escape could reach included SSH private keys, cloud credentials and anything the user's account can touch [44]. Secondary press, citing Accomplish, reports roughly 500,000 macOS users running local sessions exposed [46, 47]. The Accomplish post itself gives no such figure.
- The underlying flaw is CVE-2026-46331, a Linux kernel bug filed by the kernel's own CVE authority and fixed upstream, published 16 June 2026 [45]. It is not a Cowork CVE, and no Cowork CVE exists. Anthropic closed the disclosure as informative without issuing a direct fix, on the grounds that the CVE fell inside the bounty programme's 30 day window for recently published bugs [44, 46]. No Anthropic fix, advisory or new escape has appeared since.
- Accomplish says the path does not appear to apply to cloud execution, now the default [44]. Local execution remains available for existing desktop deployments [3], and Claude Desktop on 3P has no cloud execution [28], so the path is not removed everywhere.
- requireCoworkFullVmSandbox has been deprecated since at least April 2026, judging by its position before the first dated entry (16 April 2026) in the configuration changelog, with no named replacement [31]. My reading is that Anthropic's answer to local isolation is cloud execution. 3P does not offer it, and cloud processing cuts against the residency reason for choosing 3P.

2.7.2 Controls

What is available splits into what an administrator can set, what only Anthropic can fix, and the visibility either choice costs.

- Prefer cloud execution. Anthropic describes the cloud sandbox as sitting behind a mandatory egress proxy that the sandbox cannot reconfigure or bypass, with session scoped tokens, connector authorisation tokens kept outside the sandbox, and tenant isolation between organisations. A new organisation control governs trusted device enrolment on cloud sessions [3]. Cloud sessions can still read and write the member's connected folders through the desktop app [3].
- Where local execution stays, the fixes Accomplish recommends (block unprivileged user namespaces, make the seccomp filter deny by default, stop unused kernel modules autoloading, and stop sharing the whole host into the VM) sit inside Anthropic's VM and have no documented admin setting [44]. Accomplish argues that patching the guest kernel fixes only this one bug [44]. Ask Anthropic for them. The admin levers are keeping builds current and restricting file system sharing with allowedWorkspaceFolders (device policy in 1P, see 2.3).
- Since 4 September 2026 (v1.46388.3) users can attach their home folder, Documents, AppData, the macOS Library folder and whole drives. Claude's own configuration and certain credential locations, such as SSH keys, cloud credentials and shell profiles, are carved out [38]. This widens what a session can reach and makes allowedWorkspaceFolders more important.
- Accept the visibility cost of either choice. Anthropic states that the VM is isolated from host based security tools by design, and that cloud sessions run outside the endpoint so EDR cannot observe them either [3]. OpenTelemetry (2.6) can log both cloud and local sessions, though it is not EDR [26].

Cloud execution removes the whole-host mount, though not access to connected folders, and gives an egress boundary the sandbox cannot subvert. It also puts the session somewhere endpoint tooling cannot see it. Choose deliberately rather than by default.

3 References

Reviewed 23 September 2026. Anthropic sources are authoritative for what the controls are. Platform vendor documentation and independent research are cited where Anthropic is silent, and are marked as such in the text. Dates are the page's own published or updated date where it exposes one.

Anthropic, Help Centre and Privacy Center

[1] Claude Cowork and chat are one Claude, updated 16 September 2026. https://support.claude.com/en/articles/16761823-claude-cowork-and-chat-are-one-claude

[2] Use Claude Cowork on Team and Enterprise plans, updated 22 September 2026. https://support.claude.com/en/articles/13455879-use-claude-cowork-on-team-and-enterprise-plans

[3] Claude Cowork architecture overview, updated 16 September 2026. https://support.claude.com/en/articles/14479288-claude-cowork-architecture-overview

[4] Install Claude Desktop, updated 6 August 2026. https://support.claude.com/en/articles/10065433-install-claude-desktop

[5] Enterprise configuration for Claude Desktop, updated 2 September 2026. https://support.claude.com/en/articles/12622667-enterprise-configuration-for-claude-desktop

[6] Set up role-based permissions on Enterprise plans, updated 16 September 2026. https://support.claude.com/en/articles/13930458-set-up-role-based-permissions-on-enterprise-plans

[7] Manage custom roles on Enterprise plans, updated 22 September 2026. https://support.claude.com/en/articles/13930452-manage-custom-roles-on-enterprise-plans

[8] Manage plugins for your organization, updated 22 September 2026. https://support.claude.com/en/articles/13837433-manage-plugins-for-your-organization

[9] Provision and manage skills for your organization, updated 22 September 2026. https://support.claude.com/en/articles/13119606-provision-and-manage-skills-for-your-organization

[10] Get started with custom connectors using remote MCP, updated 11 August 2026. https://support.claude.com/en/articles/11175166-get-started-with-custom-connectors-using-remote-mcp

[11] Use connectors to extend Claude's capabilities, updated 20 August 2026. https://support.claude.com/en/articles/11176164-use-connectors-to-extend-claude-s-capabilities

[12] Manage model access for your organization, updated 1 September 2026. https://support.claude.com/en/articles/15694740-manage-model-access-for-your-organization

[13] Release notes, updated 22 September 2026. Source for connector permissions (28 May 2026) and memory off by default (25 August 2026). https://support.claude.com/en/articles/12138966-release-notes

[14] Is my data used for model training? (commercial), updated 18 August 2026. https://privacy.claude.com/en/articles/7996868-is-my-data-used-for-model-training

[15] Get started with Claude Cowork, updated 18 September 2026. https://support.claude.com/en/articles/13345190-get-started-with-claude-cowork

[16] Invite people outside your organization to an artifact, updated 18 September 2026. https://support.claude.com/en/articles/16989529-invite-people-outside-your-organization-to-an-artifact

[17] Control project sharing for your organization, updated 22 September 2026. https://support.claude.com/en/articles/9927533-control-project-sharing-for-your-organization

[18] Let Claude use your computer in Cowork, updated 16 September 2026. https://support.claude.com/en/articles/14128542-let-claude-use-your-computer-in-cowork

[19] Claude in Chrome admin controls, updated 31 August 2026. https://support.claude.com/en/articles/13065128-claude-in-chrome-admin-controls

[20] Use the built-in browser in Claude Cowork, updated 16 September 2026. https://support.claude.com/en/articles/16607400-use-the-built-in-browser-in-claude-cowork

[21] Set up browser use in Claude Cowork for Team and Enterprise plans, updated 16 September 2026. https://support.claude.com/en/articles/16635803-set-up-browser-use-in-claude-cowork-for-team-and-enterprise-plans

[22] Enforce network-level access control with tenant restrictions, updated 3 August 2026. https://support.claude.com/en/articles/13198485-enforce-network-level-access-control-with-tenant-restrictions

[23] Create and edit files with Claude, updated 6 August 2026. Source for the egress options and the self-contradictory Team default. https://support.claude.com/en/articles/12111783-create-and-edit-files-with-claude

[24] Enable and use web search, updated 22 September 2026. https://support.claude.com/en/articles/10684626-enable-and-use-web-search

[25] Access the Compliance API, updated 21 September 2026. https://support.claude.com/en/articles/13015708-access-the-compliance-api

[26] Monitor Claude Cowork activity with OpenTelemetry, updated 16 September 2026. https://support.claude.com/en/articles/14477985-monitor-claude-cowork-activity-with-opentelemetry

Anthropic, product and platform documentation

[27] Claude Cowork and chat are now one Claude (blog), 16 September 2026. https://claude.com/blog/cowork-is-now-claude

[28] Claude Desktop on 3P, Overview. Source for the provider list, the Foundry operating and residency statements and the residual Anthropic hosts. https://claude.com/docs/third-party/claude-desktop/overview

[29] Claude Desktop on 3P, Feature matrix, 17 September 2026. Source for computer use absence, Claude in Chrome in console-managed 3P, and "Claude Enterprise does not offer telemetry toggles". https://claude.com/docs/third-party/claude-desktop/feature-matrix

[30] Claude Desktop on 3P, Configuration reference, 23 September 2026. https://claude.com/docs/third-party/claude-desktop/configuration

[31] Claude Desktop on 3P, Configuration changelog. https://claude.com/docs/third-party/claude-desktop/configuration-changelog

[32] Claude Desktop on 3P, Installation and setup, 22 September 2026. Source for "The models don't combine." https://claude.com/docs/third-party/claude-desktop/installation

[33] Claude Desktop on 3P, Deploy with Enterprise Admin Console (beta), 18 September 2026. https://claude.com/docs/third-party/claude-desktop/admin-console

[34] Claude Desktop on 3P, Bootstrap. Source for the scope of the trustBootstrapDelivery prompt. https://claude.com/docs/third-party/claude-desktop/bootstrap

[35] Claude Desktop on 3P, Built-in browser and Claude in Chrome, 18 September 2026. https://claude.com/docs/third-party/claude-desktop/browser

[36] Claude Desktop on 3P, Chat, 11 September 2026. https://claude.com/docs/third-party/claude-desktop/chat

[37] Claude Desktop on 3P, User identity and local data. https://claude.com/docs/third-party/claude-desktop/data-storage

[38] Claude Desktop changelog, to v2.7032.0, 22 September 2026. https://claude.com/docs/cowork/changelog

[39] Claude Platform release notes. Entries of 3 August, 5 August, 11 August, 26 August and 18 September 2026. https://platform.claude.com/docs/en/release-notes/overview

[40] Compliance API, sessions. https://platform.claude.com/docs/en/manage-claude/compliance-sessions

[41] Web search tool, Claude Platform docs. https://platform.claude.com/docs/en/agents-and-tools/tool-use/web-search-tool

Platform vendor documentation

[42] Microsoft, Configure Claude Desktop for Microsoft Foundry, 14 July 2026. Its compliance line is out of step with Anthropic's overview [28]. https://learn.microsoft.com/en-us/azure/foundry/foundry-models/how-to/configure-claude-desktop

[43] AWS Solutions Library, Claude Cowork 3P guidance (COWORK_3P.md), last changed 17 July 2026. Source for the ccwb setting of coworkEgressAllowedHosts to ["*"]. Its statements that the Chat tab is unavailable and that computer use depends on Anthropic hosted inference are superseded by Anthropic's feature matrix [29]. https://github.com/aws-solutions-library-samples/guidance-for-claude-code-with-amazon-bedrock/blob/main/assets/docs/COWORK_3P.md

Independent security research and press

[44] Accomplish AI, SharedRoot sandbox escape, disclosed 23 July 2026. Primary source for the exploitation chain, the reachable material and the recommended fixes in 2.7. https://accomplish.ai/blog/sharedroot-escaping-claude-cowork-sandbox/

[45] CVE-2026-46331 record, Linux kernel (CNA kernel.org), published 16 June 2026. https://www.cve.org/CVERecord?id=CVE-2026-46331

[46] The Hacker News, Claude Cowork Flaw Could Let AI Agent Escape Its VM and Access Mac Files, 23 July 2026. Source, with [47], for the 500,000 exposure estimate attributed to Accomplish and for Anthropic's response. https://thehackernews.com/2026/07/claude-cowork-flaw-could-let-ai-agent.html

[47] The Next Web, Anthropic's Claude Cowork could escape its local VM and read credentials on a Mac, 26 July 2026. https://thenextweb.com/news/claude-cowork-sandbox-escape-mac-files-sharedroot

[48] Pluto Security, Inside Claude Cowork: how Anthropic's autonomous agent actually works, published 1 April 2026, modified 4 September 2026. Source for the reported 644 permissions on session log files and the contents of audit.jsonl. https://pluto.security/blog/inside-claude-cowork-how-anthropics-autonomous-agent-actually-works/

[49] Pluto Security, Securing Claude Cowork: what security teams actually need to know, published 16 April 2026, modified 4 September 2026. Source for the reported survival of child session audit logs and main.log after session deletion. Not independently verified by me and not documented by Anthropic. https://pluto.security/blog/claude-cowork-security/

[50] Harmonic Security, Securing Claude Cowork: a security practitioner's guide, published 10 March 2026, updated 14 September 2026. Corroborates the computer use position in 2.2 and is cited for nothing else. https://www.harmonic.security/resources/securing-claude-cowork-a-security-practitioners-guide

[51] Manifold Security, ClaudeBleed Reopened: Browser Extensions Can Still Push Claude for Chrome to Read Your Gmail, 14 July 2026. https://www.manifold.security/blog/claude-for-chrome-extension-bypass

[52] Forever Security (Gal Weizman), BragJack: How We Hijacked 5 Of The World's Most Popular Browsers Using Their Built-In AI Assistants, 16 September 2026. https://forever.security/blog/bragjack-hijacking-5-browsers-via-built-in-ai-assistants

[53] The Hacker News, One Extension Could Hijack AI Assistants Across Chrome, Comet, Edge, Opera Neon and Claude, 16 September 2026. Source for the vendor response and the link to LayerX's ClaudeBleed and Manifold. https://thehackernews.com/2026/09/one-extension-could-hijack-ai.html

Defect reports, anthropics/claude-code

User reports, not Anthropic statements. States are as of 23 September 2026.

[54] Issue 30112, Cowork egress allowlist not working, custom domains blocked with blocked-by-allowlist under the all domains setting. Open. https://github.com/anthropics/claude-code/issues/30112

[55] Issue 34690, the all domains setting not reflected in the session proxy token. Open. https://github.com/anthropics/claude-code/issues/34690

[56] Issue 19087, additional allowed domains not applied to container egress. Closed as a duplicate of 11897. https://github.com/anthropics/claude-code/issues/19087

[57] Issue 33386, Cowork egress allowlist not applying to subdomains. Closed as a duplicate of 30112. https://github.com/anthropics/claude-code/issues/33386

[58] Issue 93512, cloud and local sessions ignore All domains, 11 September 2026. Open, regression. https://github.com/anthropics/claude-code/issues/93512

[59] Issue 93520, Specific allowed domains ignored, 11 September 2026. Open. https://github.com/anthropics/claude-code/issues/93520

[60] Issue 93589, local egress blocked after a VM update, 11 September 2026. Closed by its author as completed on 14 September 2026, with no Anthropic fix note. https://github.com/anthropics/claude-code/issues/93589

[61] Issue 93656, All domains not applied to cloud sessions, 11 September 2026. Open. https://github.com/anthropics/claude-code/issues/93656

[62] Issue 94758, Claude Desktop on 3P with a custom gateway pins the sandbox to the gateway plus api.anthropic.com, 16 September 2026. Open, three independent reproductions. Cited as the basis for the caution about 3P enforcement in 2.4.3 and not independently verified by me. https://github.com/anthropics/claude-code/issues/94758

[63] Issue 56959, managed settings allowedDomains not honoured on Claude-3p with Bedrock, sandbox pinned to four hosts. Closed as a duplicate of 37970 on 11 May 2026, not fixed. Replaced by [62] as the 3P citation. https://github.com/anthropics/claude-code/issues/56959

[64] Issue 94848, skillCreationEnabled not enforced when set through the Claude apps gateway, 16 September 2026. Open, single report. https://github.com/anthropics/claude-code/issues/94848

[65] Issue 94866, no environment scoping on the shared ~/.claude state root (includes: sidebar Delete leaves a Code tab transcript on disk), 16 September 2026. Open. https://github.com/anthropics/claude-code/issues/94866

4 About this cheat sheet

This document is meant as an awareness-raising guide to Cowork controls. It is not a complete reference, and it is not a risk or threat assessment. As noted, new information is being discovered all the time, and it is important to check for any updates after the date of production of this file: 23 September 2026

Every claim carries a numbered citation. The sheet separates what Anthropic documents, what independent research reports, what single users have reported, and what I infer, and says which is which. Controls in this product change with most releases. Check your tenant against the date above.